UNIVERSIDAD TECNOLÓGICA DE TEHUACÁN

Desarrollo Web Profesional

Nombre del alumno:

Axel Eduardo Sánchez Ventura

INGENIERÍA EN DESARROLLO Y GESTIÓN DE SOFTWARE

Docente:

José Migue! Carrera Pacheco

Tehuacán. Puebla Enero-Abril 202ó

¿Cómo debe comportarse un formulario accesible?

Formulario diseñado siguiendo pautas WCAG que permite a personas con discapacidades (visuales, motoras, cognitivas) interactuar correctamente mediante:

- Etiquetas descriptivas (<label>) asociadas a cada campo
- Navegación por teclado lógica (orden de tabulación)
- Mensajes de error claros y ubicados cerca del campo
- Contraste de color suficiente (mínimo 4.5:1)
- Atributos ARIA cuando sea necesario (aria-required, aria-describedby)
- Campos agrupados semánticamente (<fieldset>)

¿Qué errores comunes existen en formularios de login?

Tipo	Error	Consecuencia
UX	Borrar campos al fallar	Frustración del usuario
UX	Sin indicador Caps Lock	Usuarios escriben mal la contraseña
Seguridad	Enviar sin HTTPS	Credenciales expuestas (Man-in-the-Middle)
Seguridad	Sin límite de intentos	Vulnerable a ataques de fuerza bruta
Accesibilidad	Placeholder como única etiqueta	Inaccesible para lectores de pantalla
Accesibilidad	Contraste insuficiente	No visible para personas con baja visión

¿Cómo se manejan sesiones de forma segura?

Conjunto de prácticas para proteger la identidad del usuario después de autenticarse:

- HTTP-only cookies → No accesibles por JavaScript (protección XSS)
- Secure flag → Solo se envían por HTTPS
- SameSite=Strict/Lax → Protección contra CSRF

- Rotación de ID → Nuevo ID después del login
- Tiempo de expiración → Sesiones con límite de tiempo
- Almacenamiento en servidor → No en el cliente
- Invalidación al cerrar sesión → Destruir la sesión

¿Cómo se muestran errores de autenticación sin filtrar información sensible?

Correcto:

"Credenciales inválidas"

"Usuario o contraseña incorrectos"

"Error de autenticación"

Incorrecto (filtra información):

"Usuario no encontrado" → (Revela que el usuario NO existe)

"Contraseña incorrecta" → (Revela que el usuario SÍ existe)

"Cuenta bloqueada" → (Revela estado de la cuenta)

"Último acceso: hace 3 días" → (Filtra actividad del usuario)

¿Por qué?

Para evitar que atacantes puedan:

- Enumerar usuarios válidos
- Saber qué cuentas existen
- Obtener información del sistema